ADR â€” Criptografia local e estratÃ©gia de backup do Ethos

Status
Proposto

Data
2026-04-28

Contexto

O Ethos quer evoluir para uma arquitetura **local-first**, em que o core clÃnico passa a ter o dispositivo do profissional como fonte primÃ¡ria de verdade.

Essa decisÃ£o cria duas exigÃªncias imediatas:
1. os dados clÃnicos locais precisam ser protegidos por uma estratÃ©gia clara de **criptografia em repouso**
2. o produto precisa oferecer uma estratÃ©gia de **backup e restauraÃ§Ã£o** que seja segura e operacionalmente viÃ¡vel

Sem essas duas camadas, o modelo local-first aumenta risco operacional e enfraquece a promessa de privacidade.

DecisÃ£o

DecisÃ£o principal
Adotar uma estratÃ©gia de **criptografia local obrigatÃ³ria para o core clÃnico** e uma estratÃ©gia de **backup em duas camadas**:
- **backup local criptografado** como primeira entrega obrigatÃ³ria
- **backup remoto criptografado ponta a ponta** apenas como fase posterior e opcional

EstratÃ©gia de criptografia
- todos os dados clÃnicos persistidos localmente devem ser tratados como sensÃveis
- a camada de persistÃªncia local deve suportar criptografia em repouso
- a chave de proteÃ§Ã£o deve ser derivada de uma credencial controlada pelo usuÃ¡rio ou por um mecanismo local equivalente de desbloqueio
- a aplicaÃ§Ã£o nÃ£o deve depender de servidores do Ethos para descriptografar o core clÃnico local

EstratÃ©gia de backup
- o produto deve oferecer **export local criptografado** como caminho inicial e obrigatÃ³rio
- restauraÃ§Ã£o deve funcionar sem depender do backend clÃnico
- backup remoto, quando existir, deve ser **opcional** e protegido por criptografia ponta a ponta

---

Escopo da decisÃ£o

Esta ADR cobre:
- pacientes
- sessÃµes
- prontuÃ¡rios
- documentos clÃnicos
- relatÃ³rios
- agenda principal
- metadados clÃnicos essenciais
- snapshots de backup dessas entidades

Esta ADR nÃ£o cobre em detalhe final:
- escolha definitiva do provedor de backup remoto
- desenho de sync multi-dispositivo
- compartilhamento entre profissionais
- portal do paciente
- Ethos Network

Objetivos

A soluÃ§Ã£o escolhida deve garantir:
- confidencialidade local dos dados clÃnicos
- independÃªncia do backend para acesso ao core local
- capacidade de backup e restore
- compatibilidade com futura nuvem opcional
- clareza operacional para o usuÃ¡rio

PrincÃpios

1. Privacidade por padrÃ£o
O core clÃnico deve ser protegido localmente por padrÃ£o, sem depender de opt-in manual para seguranÃ§a bÃ¡sica.

2. O servidor nÃ£o deve deter a chave do dado clÃnico local
Mesmo quando houver cloud opcional, o Ethos nÃ£o deve precisar conhecer a chave de descriptografia do conteÃºdo clÃnico do usuÃ¡rio.

3. Backup nÃ£o pode enfraquecer a privacidade
O mecanismo de backup deve preservar o mesmo padrÃ£o de proteÃ§Ã£o do armazenamento local.

4. Restore Ã© tÃ£o importante quanto backup
NÃ£o basta exportar. O fluxo de restauraÃ§Ã£o precisa ser realista, testÃ¡vel e utilizÃ¡vel.

5. O core local deve continuar operÃ¡vel sem nuvem
A recuperaÃ§Ã£o bÃ¡sica e o uso clÃnico principal nÃ£o podem depender de infraestrutura remota.

DecisÃµes arquiteturais

1. Criptografia em repouso
DecisÃ£o: o banco local e os artefatos clÃnicos persistidos devem ser protegidos por criptografia em repouso.

ImplicaÃ§Ãµes:
- dados clÃnicos nÃ£o ficam armazenados em texto puro
- documentos exportÃ¡veis sensÃveis tambÃ©m devem seguir padrÃ£o protegido quando fizer sentido
- logs locais nÃ£o devem expor conteÃºdo clÃnico bruto

2. Modelo de chave
DecisÃ£o: a chave de proteÃ§Ã£o do cofre local deve ser derivada de um segredo controlado pelo usuÃ¡rio ou por um mecanismo local equivalente.

Objetivo:
- impedir que o backend do Ethos seja prÃ©-requisito para abertura da base local
- reduzir risco de exposiÃ§Ã£o centralizada

3. Backup inicial
DecisÃ£o: a primeira versÃ£o obrigatÃ³ria do backup deve ser **backup local criptografado**, com export e restore.

RazÃ£o:
- menor dependÃªncia de nuvem
- mais coerÃªncia com a estratÃ©gia local-first
- mais simples para primeira entrega segura

4. Backup remoto
DecisÃ£o: backup remoto Ã© fase posterior e deve ser **opcional** e **E2EE**.

RazÃ£o:
- nÃ£o deve atrasar a migraÃ§Ã£o do core local-first
- nÃ£o deve enfraquecer a promessa de privacidade

5. Sync
DecisÃ£o: sync multi-dispositivo nÃ£o faz parte da primeira decisÃ£o de backup.

RazÃ£o:
- sync traz problemas diferentes de backup
- tentar resolver os dois juntos cedo demais aumenta risco arquitetural

---

Arquitetura proposta

Camadas

Camada 1 â€” Storage local protegido
ResponsÃ¡vel por:
- armazenar o core clÃnico
- garantir persistÃªncia local
- integrar com a camada de criptografia

Camada 2 â€” Crypto layer
ResponsÃ¡vel por:
- preparar dados para gravaÃ§Ã£o segura
- recuperar dados para leitura local autorizada
- apoiar export e import criptografados

Camada 3 â€” Backup local
ResponsÃ¡vel por:
- gerar pacote de backup criptografado
- permitir export manual
- permitir restore validado

Camada 4 â€” Backup remoto opcional
ResponsÃ¡vel por:
- envio opcional de backup jÃ¡ criptografado
- armazenamento remoto sem acesso ao conteÃºdo clÃnico em claro

---

Fluxo recomendado

Fluxo de uso local
1. usuÃ¡rio desbloqueia o ambiente local
2. aplicaÃ§Ã£o acessa a base protegida
3. core clÃnico opera localmente

Fluxo de backup local
1. usuÃ¡rio solicita backup
2. aplicaÃ§Ã£o gera pacote criptografado
3. usuÃ¡rio salva localmente em destino escolhido

Fluxo de restore
1. usuÃ¡rio seleciona arquivo de backup
2. aplicaÃ§Ã£o valida integridade e formato
3. aplicaÃ§Ã£o restaura a base local protegida

Fluxo futuro de backup remoto opcional
1. usuÃ¡rio ativa backup remoto
2. aplicaÃ§Ã£o envia somente artefato criptografado
3. backend remoto armazena sem acessar conteÃºdo clÃnico em claro

---

Requisitos mÃnimos

A soluÃ§Ã£o deve suportar:
- criptografia em repouso para dados clÃnicos
- export local criptografado
- import/restauraÃ§Ã£o
- integridade do backup
- separaÃ§Ã£o entre backup e sync
- operaÃ§Ã£o offline do core clÃnico
- futura extensÃ£o para backup remoto E2EE

OpÃ§Ãµes consideradas

OpÃ§Ã£o A â€” Sem criptografia local forte, apenas proteÃ§Ã£o por ambiente do navegador
Rejeitada

Motivos:
- nÃ£o sustenta a promessa de privacidade
- aumenta risco em caso de acesso indevido ao dispositivo
- fraca para contexto clÃnico

OpÃ§Ã£o B â€” Criptografia local obrigatÃ³ria + backup local criptografado + backup remoto opcional E2EE
Escolhida

Motivos:
- melhor equilÃbrio entre seguranÃ§a, viabilidade e estratÃ©gia local-first
- permite entregar proteÃ§Ã£o real cedo
- nÃ£o depende de nuvem para a primeira fase
- prepara o caminho para expansÃ£o segura depois

OpÃ§Ã£o C â€” Focar primeiro em sync e backup remoto antes do backup local
Rejeitada para esta fase

Motivos:
- aumenta complexidade cedo demais

- confunde objetivos de backup com sync
- atrasa a entrega do nÃºcleo local-first seguro

ConsequÃªncias

BenefÃcios
- fortalece a promessa de privacidade
- reduz dependÃªncia do backend para acesso ao dado clÃnico
- cria fundaÃ§Ã£o real para backup e restore
- viabiliza cloud opcional sem quebrar confidencialidade

Custos
- aumenta complexidade tÃ©cnica do frontend
- exige UX cuidadosa para desbloqueio, export e restore
- exige testes fortes de confiabilidade e integridade

Riscos
- UX ruim de chaves/senhas pode gerar fricÃ§Ã£o forte
- restore mal desenhado pode comprometer confianÃ§a
- mistura prematura entre backup e sync pode gerar arquitetura confusa

---

DecisÃµes derivadas

Depois desta ADR, o time deve produzir:
1. plano tÃ©cnico da camada de criptografia local
2. formato de backup exportÃ¡vel
3. fluxo de restore
4. polÃtica de gestÃ£o de chave local
5. checklist de riscos operacionais de perda de dados
6. plano de testes de backup e restauraÃ§Ã£o

CritÃ©rios de sucesso

Esta decisÃ£o serÃ¡ considerada correta se:
- os dados clÃnicos locais estiverem protegidos em repouso
- o usuÃ¡rio conseguir gerar backup local criptografado
- o usuÃ¡rio conseguir restaurar a base local de forma confiÃ¡vel
- o core clÃnico continuar operÃ¡vel sem backend remoto
- o futuro backup remoto puder ser acoplado sem expor conteÃºdo clÃnico em claro

---

DecisÃ£o final proposta

Adotar criptografia local obrigatÃ³ria para o core clÃnico do Ethos, com backup local criptografado como entrega inicial obrigatÃ³ria, e backup remoto ponta a ponta apenas como recurso opcional em fase posterior.